

PARA O ALTO E AVANTE

- INTRODUÇÃO À PERICIA FORENSE COMPUTACIONAL



2

LISTA DE FIGURAS

Figura 1 – Total de incidentes reportados ao CERT.br por ano	7
Figura 2 – Topologia de referência.....	14
Figura 3 - Interface do <i>script</i> para criação de usuários	15
Figura 4 - Estabelecimento de sessão SSH.....	16
Figura 5 - Comandos emitidos no console SSH (Debian01)	16
Figura 6 - Usuários logados ao host.....	17
Figura 7 – Simulação de desconexão do cabo de rede	17
Figura 8- Finalização da sessão do usuário	18
Figura 9 - Comandos executados pelo usuário	18
Figura 10 - Histórico de comandos com <i>timestamp</i>	19
Figura 11 – Cadeia de custódia.....	22
Figura 12 – Processo Forense (NIST SP800-86).....	25
Figura 13 – O modelo EDRM	28
Figura 14 – Reconhecimento do HD externo	32
Figura 15 – Identificação do HD externo	32
Figura 16 – Informações sobre o HD externo.....	33
Figura 17 – Reconhecimento do <i>pen drive</i>	33
Figura 18 – Ferramenta <i>lsusb</i>	34
Figura 19 – Informações sobre o pen drive	34
Figura 20 – Formulário parcial da cadeia de custódia.....	35
Figura 21 – Registro fotográfico do objeto questionado	36

LISTA DE TABELAS

Tabela 1 - Especificações para criação das máquinas virtuais	15
Tabela 2 - Especificações da máquina virtual	31

EMANIP

LISTA DE CÓDIGO-FONTE

Código-fonte 1 - <i>Shell script</i> para criação de usuários	16
---	----

EMANIP

LISTA DE QUADROS

Quadro 1 – Ordem de volatilidade.....	11
---------------------------------------	----

EMANIP

SUMÁRIO

INTRODUÇÃO A PERÍCIA FORENSE COMPUTACIONAL, FRAMEWORKS E MODELOS DE REFERÊNCIA	7
1 INTRODUÇÃO	7
2 ASPECTOS GERAIS RELACIONADOS À PFC	7
3 DEFINIÇÃO DE PERÍCIA FORENSE COMPUTACIONAL	9
3.1 Definição de perícia forense computacional.....	9
3.2 O princípio da troca de Locard (<i>Locard Exchange Principle</i>)	9
3.3 O princípio da incerteza de Heisenberg	10
3.4 A ordem de volatilidade (<i>Order of Volatility</i>)	11
4 A NECESSIDADE DO ALINHAMENTO LEGAL.....	12
5 O PERITO FORENSE COMPUTACIONAL E O ASSISTENTE TÉCNICO	13
6 MÃOS À OBRA	14
6.1 Entendendo na prática	14
6.2 Agora é com você!	20
7 A CADEIA DE CUSTÓDIA E A ATA NOTARIAL.....	20
8 FRAMEWORKS E MODELOS DE REFERÊNCIA	22
8.1 IETF RFC 3227	23
8.2 NIST SP800-86	24
8.3 O EDRM – Electronic Discovery reference model.....	27
8.3.1 <i>Identification</i>	28
8.3.2 <i>Preservation e Collection</i>	28
8.3.3 <i>Processing</i>	29
8.3.4 <i>Review</i>	29
8.3.5 <i>Analysis</i>	29
8.3.6 <i>Production</i>	30
8.3.7 <i>Presentation</i>	30
9 HANDS ON – IDENTIFICANDO O OBJETO QUESTIONADO	31
REFERÊNCIAS.....	37

INTRODUÇÃO A PERÍCIA FORENSE COMPUTACIONAL, FRAMEWORKS E MODELOS DE REFERÊNCIA

1 INTRODUÇÃO

Começa uma nova jornada. Iniciamos, aqui, o conteúdo sobre Perícia Forense Computacional (PFC), nem precisamos dizer o quão útil este conteúdo será no decorrer das missões junto ao seu novo cliente. Pronto para missões de investigação computacional?

2 ASPECTOS GERAIS RELACIONADOS À PFC

Ao longo das últimas décadas, o crescimento expressivo verificado em relação ao uso dos recursos e serviços computacionais trouxe consigo novas e deturpadas formas de utilização dos computadores, as quais passaram a ser empregadas, também, como poderosas ferramentas em condutas delituosas, fato que, entre outras maneiras, pode ser verificado por meio da escalada de incidentes de segurança reportados ao CERT.br.

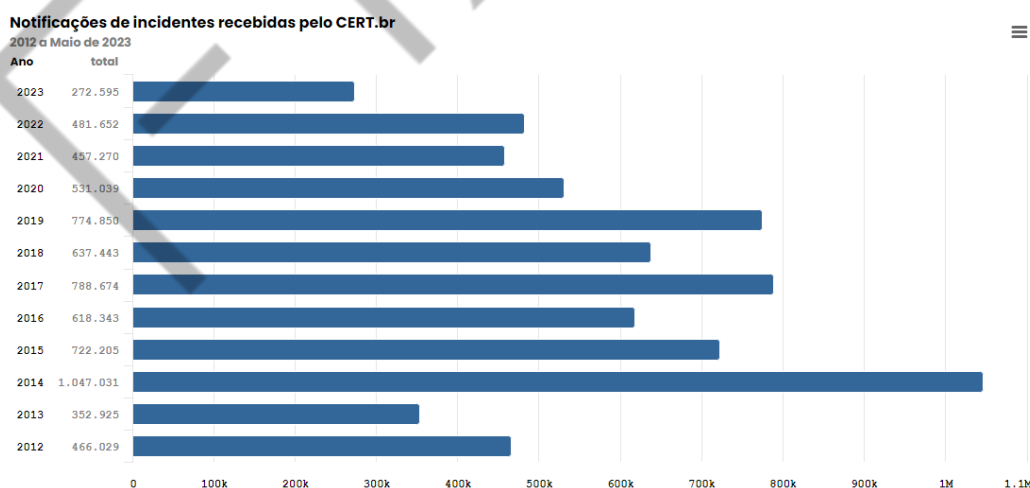


Figura 1 – Total de incidentes reportados ao CERT.br por ano
Fonte: CERT.BR (2013)

A figura “Total de incidentes reportados ao CERT.br por ano” expressa graficamente o total de incidentes anualmente reportados ao CERT.br no período compreendido entre 1999 e 2017.

Não obstante, medidas foram necessárias para a investigação dessa modalidade de crime no Brasil e nos outros países, como a da criação da *Cyber Division* (FBI) e da Delegacia de Delitos Cometidos por Meios Eletrônicos (DIG/DEIC), em São Paulo. Alguns fatores podem ser citados para compreender a escalada desse tipo de crime, conforme aponta Arruda (2018, p. 2) “a falsa sensação de anonimato proporcionada pelos computadores, aliada à possibilidade de ganhos financeiros sem violência nem qualquer interação física com a vítima, e ainda, a notória profusão dos serviços computacionais”.

Horsewell (2004) e Castro Júnior et al. (2012) refletem que Edmond Locard (1877-1966), cientista forense do início do século XX, postulou um dos princípios fundamentais da ciência forense, conhecido como o Princípio da Troca de Locard (*Locard Exchange Principle*) todo contato deixa vestígios. Dessa maneira, de um lado, o autor do delito deixa vestígios de sua passagem no local de crime e, de outro, o autor do delito leva consigo vestígios de sua permanência (ou ações) no local de crime.

Já Lazaridis, Arampatzis e Poulos (2009) apud Arruda (2018, p. 2) definem a perícia computacional como:

[...] como forense computacional, a ciência que trabalha com a descoberta, validação e interpretação de evidências digitais encontradas em dispositivos eletrônicos, tendo como principais objetivos a recuperação e preservação dessas evidências, o que permite afirmar, por analogia com o mundo real, que quando da perpetração de um crime informático, o computador também passa a ser um local de crime e, dessa maneira, objeto das práticas forenses pertinentes.

Segundo Vianna (2001), os crimes informáticos podem se apresentar sob diferentes formas: (a) crimes informáticos impróprios, nos quais o computador é mero instrumento de realização do crime, não havendo violação de dados, como nos casos de difamação, calúnia e injúria; (b) crimes informáticos próprios, nos quais o bem jurídico violado são os dados computacionais; (c) crimes informáticos mistos, nos quais há a violação de dados computacionais e de outros bens jurídicos distintos e ainda (d) crimes informáticos mediatos ou indiretos, os quais servem de instrumento para a consumação de outro delito não informático, como no caso de furto de dinheiro de contas bancárias pelo computador.

Logo, a forense computacional poderá oferecer uma contribuição relevante não apenas para esclarecimento de incidentes de segurança da informação, mas também, para fortalecimento das políticas e processos relacionados à segurança da informação em ambiente corporativo.

Ao responder aos mesmos questionamentos formulados no mundo real (HORSWELL, 2004), a forense computacional poderá contribuir, dentre outros aspectos, para a apuração da autoria e das circunstâncias que possibilitaram a consumação do ilícito: identificação das credenciais utilizadas (Quem?) e ações executadas pelo autor no sistema alvo (O quê?), determinação da cronologia dos eventos (Quando?), da origem (Onde?) e da motivação (Por quê?) do incidente, dentre outros pontos

3 DEFINIÇÃO DE PERÍCIA FORENSE COMPUTACIONAL

3.1 Definição de perícia forense computacional

A perícia forense computacional digital pode ser definida como a ciência que trabalha com a descoberta, validação e interpretação de evidências digitais encontradas em dispositivos eletrônicos – muitas vezes, relacionadas a um crime informático, tendo como principais objetivos a recuperação e a preservação dessas evidências a fim de garantir sua aplicabilidade a eventuais demandas judiciais (LAZARDIS; ATAMPATZIS; POUROS, 2009). Já de acordo com Chan (2011), o termo “forense digital” poderá ter diferentes significados em função do contexto ao qual estiver inserido, adotando, assim, o mais comumente aceito: a forense digital representa o conjunto de ferramentas e técnicas para recuperação, preservação e exame de evidências digitais em, ou transmitidas por dispositivos digitais.

3.2 O princípio da troca de Locard (*Locard Exchange Principle*)

Edmond Locard (1877-1966), cientista forense do início do século XX, postulou um dos princípios fundamentais da ciência forense conhecido como o Princípio da Troca de Locard (*Locard Exchange Principle*), o qual é sinteticamente

expresso por Chan (2011), ao afirmar que do contato entre dois itens sempre haverá uma troca. Assim sendo, é possível afirmar que o autor do ilícito sempre deixará vestígios de sua passagem no local de crime, bem como, levará consigo vestígios de sua permanência e/ou de suas ações neste (HOSWELL, 2004). Frente a isso, é possível afirmar, ainda, não importar o quanto esse indivíduo tente ocultar seus rastros, sempre serão deixadas evidências (CHAN, 2011). Tal fato pode ser observado no mundo real quando, por exemplo, uma bala disparada auxilia no rastreamento de retorno à arma que executou o disparo. Já no mundo digital, arquivos de *log*, dentre outros exemplos, podem registrar, local ou remotamente, as ações de suspeitos, e mesmo que esses venham a apagar ou adulterar os *logs*, outras evidências serão deixadas no sistema alvo do incidente, tais como os horários de modificação de arquivos e o uso de múltiplos arquivos de *log*.

3.3 O princípio da incerteza de Heisenberg

Na Física Clássica, também conhecida como Física Newtoniana, acreditava-se que, dada a posição inicial e o momento (massa e velocidade) das partículas de um sistema, seria possível calcular suas interações e, assim, prever o comportamento do sistema (GTA-UFRJ, 2007). Inicialmente, tal afirmação pode parecer correta se as interações entre as partículas puderem ser efetivamente descritas com precisão, entretanto, ela pressupõe duas condições fundamentais: serem conhecidos o momento e a posição de todas as partículas. Todavia, segundo o Princípio da Incerteza de Heisenberg, não é possível se conhecer com absoluta precisão a posição ou o momento e, portanto, a velocidade de uma partícula, uma vez que a medição de qualquer desses parâmetros acabará por alterá-los.

Farmer e Venena (2011) fazem uma aplicação desse princípio ao contexto de coleta de dados, uma vez que os computadores não são definidos em função de um determinado momento, mas sim por uma série contínua. Dessa maneira, memória, processos e arquivos podem ser entidades tão dinâmicas que o registro preciso e sincronizado de suas atividades não é possível sem perturbar profundamente a operação de um sistema computacional típico.

3.4 A ordem de volatilidade (*Order of Volatility*)

A abordagem a um sistema computacional para coleta de dados e posterior processamento para fins forenses deve ser feita de forma planejada e metodológica, a fim de se garantir a devida integridade e preservação da evidência digital (FARMER e VENEMA, 2011). Dessa maneira, deve-se atentar ao fato de que, quanto mais volátil (quanto mais efêmera) for a evidência digital, mais suscetível a perdas e modificações indevidas ela se torna, fazendo-se necessário, portanto, que os procedimentos investigativos sejam conduzidos à luz de uma hierarquia precisa, baseada na expectativa de vida dessa evidência, denominada Ordem de Volatilidade, conforme você poderá observar no Quadro “Ordem de Volatilidade”.

Aliando-se ao Princípio da Incerteza de Heisenberg, é possível concluir também que a abordagem a uma determinada camada contaminará – mesmo que discretamente, as evidências (dados) em camadas superiores. Tome-se como exemplo as alterações causadas ao conteúdo da RAM e aos registradores da CPU em decorrência de um processo originado pela execução de alguma ferramenta para coleta das conexões de rede ativas no sistema sob investigação (objeto questionado).

Tipos de dados	Tempo de vida
Registradores, memórias periféricas, caches etc.	Nanossegundos
Memória principal	Dez nanossegundos
Estado da rede	Milissegundos
Processos em execução	Segundos
Disco	Minutos
Disquetes, mídias de backup, etc.	Anos
CD-ROMs, impressões etc.	Dezenas de anos

Quadro 1 – Ordem de volatilidade
Fonte: Farmer e Venema (2011)

Ainda, sobre a ordem de volatilidade, Arruda (2018, p. 9-10) cita assim:

[...] é possível observar ser praticamente impossível a obtenção dos dados residentes nos registradores, memórias periféricas, caches e análogos em ambientes não controlados, dada a alta efemeridade de tais evidências. Cabe salientar, ainda, serem os dados residentes abaixo da camada de Processos, objetos de procedimentos forenses *post-mortem*, assim sendo, restringe-se a

efetiva aplicação da Ordem de Volatilidade neste contexto introdutório, às camadas compreendidas por: Memória principal, Estado da rede e Processos em execução.

4 A NECESSIDADE DO ALINHAMENTO LEGAL

Dada a natureza da perícia forense computacional, a licitude e, portanto, a admissibilidade da evidência digital produzida é totalmente dependente da observância dos preceitos legais aplicáveis.

É interessante que o analista/perito forense computacional possua conhecimento jurídico básico a fim de melhor direcionar suas ações, não cabendo a esse, entretanto, a interpretação da lei – tarefa de competência dos operadores do Direito.

Considere-se o caso de *insiders* que venham a vaziar informações sigilosas de uma empresa. De acordo com Gomes (2015), uma empresa paulista perdeu mais de R\$2.250.000,00 diários após um de seus funcionários vender as informações do banco de dados da empresa a um concorrente.

A solução encontrada pela empresa para tratar e prevenir futuros danos foi construída com base na adoção de diversas medidas, dentre outras, controladoria interna, criação de cartilha de conduta cibernética, proibição do uso de *e-mails* pessoais nos computadores da empresa e o **monitoramento de todas as atividades** de seus funcionários. Nesse contexto, vale citar a Teoria da Árvore Envenenada. Originada no direito norte-americano, essa teoria postula, de forma simplificada, que todas as provas obtidas a partir de uma prova ilícita também serão ilícitas. Logo, se o monitoramento de funcionários contemplar práticas como a abertura dos *e-mails* e/ou documentos desses sem a devida concordância com as determinações legais, eventualmente assim, implicando na quebra da privacidade desses funcionários, a empresa poderá vir a ter problemas, uma vez que, de acordo com o Inciso X do Artigo 5 da Constituição Federal de 1988, tem-se:

Art. 5º Todos são iguais perante a lei, sem distinção de qualquer natureza, garantindo-se aos brasileiros e aos estrangeiros residentes no País a inviolabilidade do direito à vida, à liberdade, à igualdade, à segurança e à propriedade, nos termos seguintes:

X - são invioláveis a intimidade, a vida privada, a honra e a imagem das pessoas, assegurado o direito a indenização pelo dano material ou moral decorrente de sua violação; (BRASIL, 1988)

Assim sendo, caso no decorrer de investigação para resposta a um incidente de segurança no ambiente corporativo, o analista forense venha a indevidamente quebrar a privacidade de um usuário (funcionário), além da impossibilidade de uso legal das informações obtidas, a empresa poderá vir a ser judicialmente responsabilizada por quebra de privacidade.

Portanto, torna-se evidente a necessidade e relevância de políticas (termo) de uso dos sistemas informáticos corporativos, além da conscientização e aceitação formais por parte dos usuários de tais recursos, em relação à possibilidade de acesso a informações particulares no contexto descrito.

Do exposto, é possível observar, ainda, mesmo que indiretamente, que diferentemente da auditoria, a perícia forense computacional busca, essencialmente, a coleta e a preservação da evidência digital com o objetivo de responder a questionamentos relacionados a uma conduta antijurídica, ou no contexto deste estudo, à resposta a um incidente de segurança da informação em ambiente corporativo. Em ambos os casos, entretanto, sempre à luz das determinações legais a fim de garantir a legitimidade, integridade e admissibilidade dessa evidência, especialmente quando efetivamente destinadas a demandas judiciais. A auditoria por sua vez, busca basicamente a conformidade com práticas e padrões tomados como referência.

5 O PERITO FORENSE COMPUTACIONAL E O ASSISTENTE TÉCNICO

Do disposto pela legislação vigente à época deste trabalho, em relação ao exame do corpo de delito e das perícias em geral: “O exame de corpo de delito e outras perícias serão realizados por perito oficial, portador de diploma de curso superior (BRASIL, 2008)”, conclui-se que o requisito mínimo aos que pretendem se tornar peritos forenses é a graduação em nível superior. O perito forense (ou perito judicial) é nomeado por juiz, tornando-se, dessa forma, representante da Justiça na

perícia judicial, portanto, investido de fé pública. Já o assistente técnico é o auxiliar da parte, aquele que tem por obrigação concordar, criticar ou complementar o laudo do perito oficial, por meio de seu parecer, cabendo ao juiz, pelo princípio do livre convencimento, analisar seus argumentos, podendo fundamentar sua decisão nesse parecer.

6 MÃOS À OBRA

6.1 Entendendo na prática

A fim de colocar-se em prática um apanhado da fundamentação teórica até aqui construída, tome-se como exemplo um acesso via SSH a um *host* da rede local de uma determinada empresa, em relação ao qual questiona-se:

- Qual o endereço IP do host de origem da conexão?
- Qual o username utilizado para autenticação?
- Quando ocorreu tal acesso?
- Quais as ações executadas por esse usuário no host remoto?

A figura “Topologia de referência” ilustra o diagrama da topologia utilizada:

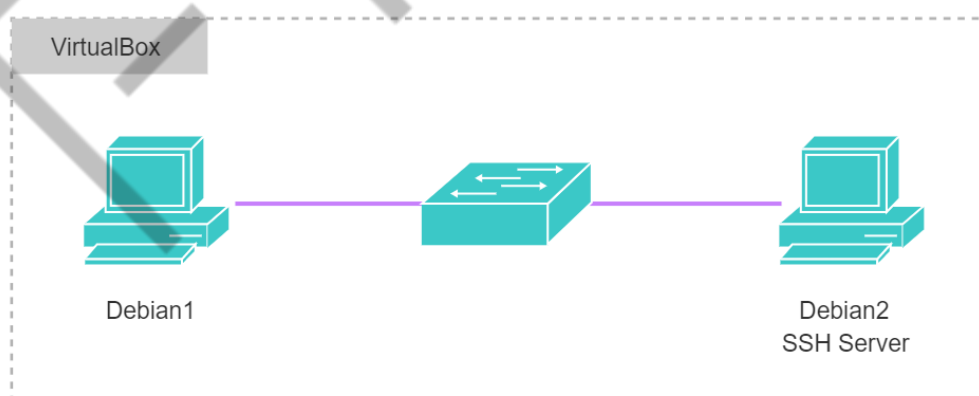


Figura 2 – Topologia de referência
Fonte: Elaborado pelo autor (2019)

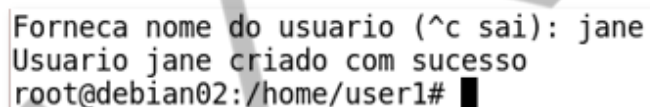
A tabela “Especificações para criação das máquinas virtuais” traz essas especificações.

Parâmetro	Especificação
Hypervisor	VirtualBox
Sistema operacional	Debian 9 64bitsStretch
Memória	1GB
Disco	8GB
Rede	Rede NAT
vCPU	1

Tabela 1 - Especificações para criação das máquinas virtuais

Fonte: Elaborado pelo autor (2019)

Em um terminal privilegiado no *host* Debian02, crie os usuários Bob e Jane (Figura “Interface do *script* para criação de usuários”) com base no *script* *criausr.sh* (Código-Fonte “Shell script para criação de usuários”). Não se esqueça de atribuir permissão de execução ao usuário (*chmod u+x*), se não, em termos práticos, o *script* não será nada além de um “arquivo texto constituído por palavras reservadas”, ou seja, não poderá ser executado (a menos que seja invocado diretamente pelo *bash*).



```
Forneça nome do usuario (^c sai): jane
Usuario jane criado com sucesso
root@debian02:/home/user1#
```

Figura 3 - Interface do *script* para criação de usuários

Fonte: Elaborado pelo autor (2019)

```
#!/bin/bash
#
usrshell="/bin/bash"
#
criausr(){
clear
read -p "Forneça nome do usuario (^c sai): " user
grep $user /etc/passwd > /dev/null
if [ $? -eq 0 ]; then
    read -p "Usuario existente, pressione algo para
recomeçar" i
    criausr
else
    useradd -m -d /home/$user -s $usrshell -c "Usuario $user"
    $user && \
    echo "Usuario $user criado com sucesso"
    echo "Forneça a senha inicial para o usuario"
    passwd $user
fi
}
criausr
```

Código-fonte 1 - *Shell script* para criação de usuários

Fonte: Elaborado pelo autor (2019)

Criados os referidos usuários, a partir de um terminal desprivilegiado no *host* Debian01 estabeleça uma conexão SSH para o *host* Debian02 utilizando o usuário bob (Figura “Estabelecimento de sessão SSH”).

```
user1@debian01:~$ ssh bob@10.0.2.23
bob@10.0.2.23's password:
Linux debian02 4.9.0-4-amd64 #1 SMP Debian 4.9.65-3+deb9u1 (2017-12-23) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Fri Nov 16 19:06:39 2018 from 10.0.2.39
bob@debian02:~$
```

Figura 4 - Estabelecimento de sessão SSH

Fonte: Elaborado pelo autor (2019)

Estabelecida a referida conexão, é possível verificar, na última linha da Figura “Estabelecimento de sessão SSH”, a alteração do *username* de user1 para bob, e do *hostname* de debian01 para debian02. No terminal da conexão SSH, emita os comandos ilustrados na Figura “Comandos emitidos no console SSH (Debian01)”, os quais servirão como controle para posterior comparação com os comandos apurados pelo investigador no *host* Debian02.

```
bob@debian02:~$ hostname -I
10.0.2.23
bob@debian02:~$ hostname
debian02
bob@debian02:~$ tail -n2 /etc/passwd
bob:x:1001:1001:Usuario bob:/home/bob:/bin/bash
jane:x:1002:1002:Usuario jane:/home/jane:/bin/bash
bob@debian02:~$ id
uid=1001(bob) gid=1001(bob) grupos=1001(bob)
bob@debian02:~$
```

Figura 5 - Comandos emitidos no console SSH (Debian01)

Fonte: Elaborado pelo autor (2019)

O comando **hostname -I** retorna o endereço IP do *host* local (10.0.2.23), no caso: *host* Debian02; conforme indicado no *prompt de comando*.

Na segunda linha da mesma figura, o comando *hostname* é novamente empregado – desta vez, entretanto, sem argumentos, dessa maneira, retornando o nome do *host* (debian02). Na terceira linha, o comando *tail -n2 /etc/passwd* (Figura “Comandos emitidos no console SSH (Debian01)”) retorna informações sobre as

credenciais dos dois últimos usuários criados no *host*: bob e jane. Finalmente, o comando *id* retorna informações importantes a respeito do usuário corrente, como seu uid, gid e grupos aos quais pertence. Passando-se, então, ao *host* Debian-02, inicia-se a investigação logando com as credenciais do usuário user1, abrindo um terminal, e verificando os usuários atualmente logados ao *host* por meio do comando *w* (Figura “Usuários logados ao host”).

```
user1@debian02:~$ w
19:29:08 up 3:19, 6 users, load average: 0,00, 0,00, 0,01
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
bob       pts/0    10.0.2.39       19:09    12:04  0.28s  0.28s -bash
user1     tty2     :0              11:36    2days 2:38   0.03s /usr/lib/gnome-
user1@debian02:~$ su
Senha:
root@debian02:/home/user1#
```

Figura 6 - Usuários logados ao host
Fonte: Elaborado pelo autor (2019)

Nessa figura, é possível observar que o usuário bob encontra-se remotamente conectado ao *host* (Debian02), a partir do *host* Debian01 (10.0.2.39), por meio de um pseudo-terminal (pts/0) que lhe fornece um *shell* válido (*bash*), o que lhe permite, portanto, a execução de comandos no *host* Debian02. Constatada, assim, a existência do acesso remoto, o cabo de rede do objeto questionado (Debian02) deverá ser removido (Figura “Simulação de desconexão do cabo de rede”), a fim de garantir-se a preservação do ambiente e das conexões ativas; assumindo-se, na sequência, a identidade do *root* por meio do comando *su* (Figura “Usuários logados ao host”). A simulação da desconexão do cabo de rede poderá ser feita no VirtualBox acessando-se o menu principal da VM, e clicando-se em Dispositivos > Rede > Conectar a placa de rede (Figura “Simulação de desconexão do cabo de rede”).

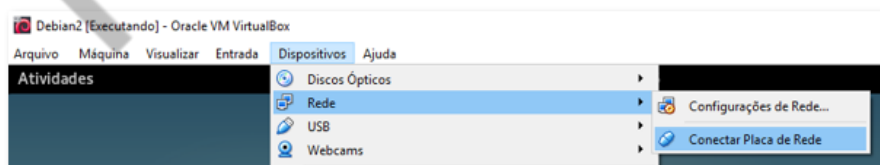


Figura 7 – Simulação de desconexão do cabo de rede
Fonte: Elaborado pelo autor (2019)

Por meio do comando *ps* é possível verificar todos os processos relacionados ao usuário bob, identificando, dentre esses, qual o responsável pelo respectivo *shell*.

Os comandos executados pelo usuário Linux permanecem em memória até que sua sessão seja finalizada. Assim sendo, o processo responsável pelo *shell* do usuário deverá ser adequadamente encerrado, a fim de que os comandos

executados no objeto questionado sejam gravados em seu respectivo arquivo `.bash_history`. Dessa maneira, será possível a utilização das informações contidas nesse arquivo como evidências importantes.

Na figura “Finalização da sessão do usuário”, a linha de comando ilustrada solicita o detalhamento de todos os processos relacionados ao usuário bob, dos quais é possível verificar, por meio do destaque, o processo relacionado ao respectivo *shell* (remoto).

```
root@debian02:/home/user1# ps aux | grep bob [a]
root   8936  0.0  0.6 101432 6956 ?        Ss   19:09   0:00 sshd: bob [priv]
bob    8938  0.0  0.6 65024 6384 ?        Ss   19:09   0:00 /lib/systemd/systemd --user
bob    8939  0.0  0.1 234264 1464 ?        S    19:09   0:00 (sd-pam)
bob    8947  0.0  0.4 101432 4252 ?        S    19:09   0:00 sshd: bob@pts/0
bob    8948  0.0  0.4 21104 5032 pts/0    Ss+  19:09   0:00 -bash
root   9114  0.0  0.0 12784 940 pts/1    S+   19:51   0:00 grep bob
root@debian02:/home/user1# kill 8948 [b]
root@debian02:/home/user1#
```

Figura 8- Finalização da sessão do usuário

Fonte: Elaborado pelo autor (2019)

O comando *kill* (Figura “Finalização da sessão do usuário[b]”) envia um sinal *sigterm* (-15) ao processo 8948, dessa forma, encerrando adequadamente a sessão do usuário. Se o processo for fechado corretamente (nem sempre a aplicação responde como esperado a um sinal *sigterm*), o histórico de comandos executados pelo usuário será gravado em disco, podendo ser recuperado conforme ilustrado pela Figura “Comandos executados pelo usuário”.

```
root@debian02:/home/user1# cat /home/bob/.bash_history
date
df -hT
du -sh
ls -l
firefox
mkdir teste
cd teste/
ls
cd -
rmdir teste/
hostname -I
hostname
tail -n2 /etc/passwd
id
root@debian02:/home/user1#
```

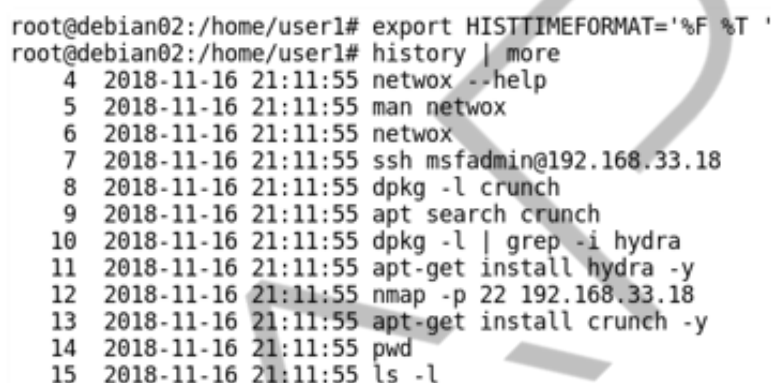
Figura 9 - Comandos executados pelo usuário

Fonte: Elaborado pelo autor (2019)

Nessa figura, é possível observar que os comandos enviados para controle (Figura “Comandos emitidos no console SSH (Debian01)”) foram gravados adequadamente no histórico de comandos do usuário, entretanto, é possível se constatar também uma característica indesejada inerente à configuração padrão do

comando *history*: ele não gera registros que permitam determinar a cronologia (apenas a sequência) dos comandos executados, uma vez que não gera *timestamps*.

Assim sendo, é possível concluir, ainda, que a forense computacional em ambiente corporativo pode contribuir também para melhor configuração dos sistemas informáticos e implementação de controles para segurança da informação. A Figura “Histórico de comandos com *timestamp*” exemplifica a utilização do comando *history* com *timestamp* habilitado.

A terminal window showing the output of the 'history' command. The prompt is 'root@debian02:/home/user1#'. The command 'export HISTTIMEFORMAT='%F %T '' has been entered. Then 'history | more' is entered, and the following list of commands with timestamps is displayed:

```
4 2018-11-16 21:11:55 netwox --help
5 2018-11-16 21:11:55 man netwox
6 2018-11-16 21:11:55 netwox
7 2018-11-16 21:11:55 ssh msfadmin@192.168.33.18
8 2018-11-16 21:11:55 dpkg -l crunch
9 2018-11-16 21:11:55 apt search crunch
10 2018-11-16 21:11:55 dpkg -l | grep -i hydra
11 2018-11-16 21:11:55 apt-get install hydra -y
12 2018-11-16 21:11:55 nmap -p 22 192.168.33.18
13 2018-11-16 21:11:55 apt-get install crunch -y
14 2018-11-16 21:11:55 pwd
15 2018-11-16 21:11:55 ls -l
```

Figura 10 - Histórico de comandos com *timestamp*
Fonte: Elaborado pelo autor (2019)

Produzidas e devidamente analisadas as evidências necessárias, é hora, então, de responder à quesitação formulada de maneira formal. É muito importante ter sempre em mente que a produção do laudo pericial deverá ser alinhada com o perfil do destinatário deste: um advogado, uma autoridade ou mesmo um gestor, dentre outros.

Alguns dos princípios básicos a se observar quando da produção do laudo pericial, ou no caso deste exemplo prático, um “parecer técnico” simplificado, são:

- Uso de linguagem formal, porém, simples. Minimizar o uso de termos técnicos, especialmente, se pouco conhecidos ou que possam gerar dúvidas.
- Formular respostas tão curtas, claras e objetivas quanto possível.
- Não responder a quesitos de forma que o demandante seja forçado a tirar conclusões por si só. Por exemplo, informações contidas em um *print* de tela sem os esclarecimentos e comentários cabíveis.

- Sempre sustentar as respostas à quesitação com a compilação das evidências produzidas.

6.2 Agora é com você!

De posse das evidências e das respostas à quesitação formulada, elabore seu laudo pericial tomando como base as seguintes referências:

- *Report Writing for Digital Forensics: Part II* (<https://www.sans.org/blog/report-writing-for-digital-forensics-part-ii/>).
- *Forensic Examination of Digital Evidence: A Guide for Law Enforcement*. (<https://www.ojp.gov/pdffiles1/nij/199408.pdf>).
- *Guide to Integrating Forensic Techniques into Incident Response*. (<https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-86.pdf>).

Caso julgue necessário, faça uso das referências citadas, com certeza você terá condições de evoluir dentro da atividade proposta e aguçar ainda mais os seus sentidos investigativos.

7 A CADEIA DE CUSTÓDIA E A ATA NOTARIAL

Tome como exemplo a necessidade de preservação de uma conversa pelo WhatsApp, a qual deverá servir como evidência em demanda judicial. Normalmente, o processo se iniciaria pela captura da tela do aplicativo, a qual poderia ser posteriormente impressa e anexada a uma petição. Entretanto, tal procedimento produziria uma evidência inidônea.

De acordo com Martins (2018), a extração da evidência deverá ser executada por especialista na área, a fim de se garantir a confidencialidade, integridade, disponibilidade, autenticidade e não repúdio (pilares da Segurança da Informação). Ainda segundo esse autor, para que a validade jurídica da evidência coletada também seja garantida, o perito deverá valer-se de serviços notariais para a confecção de ata notarial: instrumento público pelo qual o tabelião, ou preposto autorizado, a pedido de

pessoa interessada, constata fielmente os fatos, as coisas, pessoas ou situações para comprovar a sua existência, ou o seu estado.

Martins (2018) recomenda, ainda, que a condução de qualquer procedimento para fins forenses seja acompanhada por profissional qualificado, uma vez que eventuais erros na execução de tais procedimentos poderão tornar a evidência questionável em diferentes formas. Os passos a seguir resumem o processo de custódia da evidência digital no cenário hipotético proposto, referente à extração de uma conversa do WhatsApp, instalado em um smartphone:

- Após a devida identificação da conversa a ser preservada, ativar o modo avião do aparelho a fim de inibir a conexão com a Internet, impedindo, assim, o eventual apagamento (mesmo que parcial) da conversa.
- Acondicionar o aparelho de forma adequada ao transporte.
- Procurar um cartório de notas a fim de providenciar a elaboração de uma ata notarial.
- Durante a elaboração desta, incluir na narrativa dos fatos, dados que identifiquem inequivocamente o aparelho: número de série, IMEI, endereço MAC e número do SIM card, dentre outras informações.
- Solicitar ao serventuário do cartório a captura de tela ou a extração da conversa, acompanhada dos *hashes* de cada arquivo digital coletado: imagens, códigos-fonte e arquivos texto, dentre outros. Solicitar, ainda, que os resultados constem na ata notarial, na sequência, acondicionando os arquivos coletados no dispositivo, em mídia adequada.
- Elaborada a ata notarial, será então produzida a evidência digital conforme os padrões das normas técnicas da computação forense.

Martins (2018) recomenda depositar o aparelho em Juízo ou em empresa privada de custódia de evidências digitais, juntamente com a mídia produzida, uma vez que existe a possibilidade de ser deferida prova pericial pelo Juízo.

Do exposto, conclui-se que, em linhas gerais, a cadeia de custódia consiste de um processo de registro metódico, cronológico, cuidadoso e detalhado sobre a busca e apreensão, manuseio, custódia, controle e caminho dos vestígios coletados no local

de um crime, que depois de analisados terão seu resultado apresentado em forma de laudo pericial (Niella, 2016). Ainda segundo o mesmo autor, a cadeia de custódia serve para garantir a integridade da prova: “Ela é importante porque garante a idoneidade e rastreabilidade dos vestígios com a finalidade de preservar a confiabilidade e transparência até que o processo seja concluído”.

FORMULÁRIO DE CADEIA DE CUSTÓDIA						
NÚMERO DO CASO		20090226				
DETALHES DA MÍDIA OU EQUIPAMENTO						
ITEM	DESCRIÇÃO					
1	HD DO NOTEBOOK COM 2 GB DE CAPACIDADE					
FABRICANTE		MODELO		NÚMERO DE SÉRIE		
SAMSUNG		SGM2GB		ABC123456		
SOBRE A IMAGEM DOS DADOS						
DATA	HORA	CRIADA POR		FERRAMENTA USADA		
26/2/2009	10:53	SÍLVIO DO MONTE		EnCASE VERSION 3		
TIPO DE CÓPIA		HASH				
DISCO COMPLETO		4e3d2d5e5427953d7eda6ddc6627bf6b				
CADEIA DE CUSTÓDIA						
CÓDIGO	ORIGEM	DATA	HORA	DESTINO	DATA	HORA
1	LOCAL DE APREENSÃO	26/2/2009	17:00	PERÍCIA	26/2/2009	17:30

Figura 11 – Cadeia de custódia
Fonte: Google Imagens (2019)

A figura “Cadeia de custódia” ilustra um modelo do citado instrumento, por meio do qual é possível verificar a detalhada identificação do objeto questionado, o tipo de imagem forense executada e o respectivo *hash*, dentre outras informações.

8 FRAMEWORKS E MODELOS DE REFERÊNCIA

A condução correta dos procedimentos periciais depende da observância dos modelos de referência e *frameworks* aplicáveis, a fim também, de garantir os resultados desejados ao final dos trabalhos.

Dentre os principais modelos de referência e *frameworks* existentes, destacam-se aqui, de forma sucinta, três dos mais difundidos:

8.1 IETF RFC 3227

De acordo com a RFC 3227, um “incidente de segurança”, conforme definido pelo Glossário de Segurança da *Internet* [RFC 2828] (<https://datatracker.ietf.org/doc/html/rfc2828>), é um evento de sistema relevante para a segurança no qual a política de segurança do sistema é infringida ou violada. O objetivo da RFC 3227 é fornecer, aos Administradores de Sistema, diretrizes a respeito da coleta e arquivamento de evidências relevantes para tal incidente de segurança. Dentre os princípios propostos pela RFC 3227 para orientar a coleta de evidências, destacam-se aqui:

- Aderência à política de segurança local e envolvimento do pessoal responsável pelo tratamento de incidentes (*incident handlers*) e aplicação da lei.
- Produção de imagem forense do sistema, tão fiel quanto possível.
- Produção de documentação detalhada, incluindo cronologia (data e hora), devidamente assinada e datada.
- Atentar à diferença entre o relógio do sistema e o UTC, indicando para cada *timestamp* fornecido, qual desses foi utilizado.
- Esteja preparado para testemunhar (mesmo que anos mais tarde), tomando notas detalhadas de todas as ações executadas durante as diversas fases do procedimento pericial, e em quais momentos.
- Minimize a contaminação (alteração) dos dados a serem coletados, não apenas em relação ao seu conteúdo, mas também em relação aos respectivos *mac times*.

O IETF, por meio da RFC 3227, recomenda explicitamente, a observância da Ordem de Volatilidade, sugerindo que os procedimentos periciais se iniciem pelas evidências de maior volatilidade prosseguindo, então, para as menos voláteis. Atenção especial deverá ser dispensada também à privacidade dos indivíduos, a qual é claramente referenciada no inciso X do artigo 5º da Constituição Brasileira de 1988. A referida RFC define, ainda, que a evidência digital deve ser:

- 1 **Admissível:** deve estar em conformidade com as prescrições legais aplicáveis, antes de ser submetida a um tribunal.
- 2 **Autêntica:** deve ser possível se relacionar inequivocamente o material probatório ao incidente.
- 3 **Completa:** deve contar toda a história e não apenas uma perspectiva particular.
- 4 **Confiável:** não deverá haver nada relacionado à coleta e à posterior manipulação da evidência, que possa levantar dúvidas sobre a autenticidade e veracidade da evidência.
- 5 **Crível ou Acreditável:** a evidência deve ser prontamente acreditável e compreensível por um tribunal.

A cadeia de custódia deve ser capaz de descrever claramente como a evidência foi encontrada, como ela foi tratada e tudo o que aconteceu a ela, devendo-se documentar claramente:

- **Onde, quando e por quem** a evidência foi descoberta e coletada.
- **Onde, quando e por quem** as evidências foram tratadas ou examinadas.
- **Quem** teve a custódia da evidência, durante o período. Como foi armazenado.
- **Quando** a evidência mudou de custódia, **quando** e **como** ocorreu a transferência (inclui números de envio, entre outros).

8.2 NIST SP800-86

Considerando-se que diferentes organizações estão sujeitas a diferentes dispositivos legais e diferentes regulamentações, a *Special Publication* 800-86 do NIST alerta para o fato de que essa publicação não deve ser usada como guia para a execução de investigações forenses digitais, interpretada como aconselhamento jurídico ou usada como base para investigações de atividades criminosas. Ao invés disso, esse documento propõe-se a ser utilizado como um ponto de partida para desenvolvimento da capacitação forense, conjuntamente com a devida orientação

oferecida por consultores jurídicos, autoridades responsáveis pela aplicação da lei, e gerenciamento.

As organizações devem garantir que suas políticas abordem claramente todas as principais considerações relacionadas às práticas forenses, tais como contatar as autoridades policiais, proceder ao monitoramento e revisar regularmente as políticas e procedimentos forenses.

A SP800-86 fornece recomendações gerais para execução do processo forense, bem como informações detalhadas referentes ao processo de análise das quatro principais categorias de fontes de dados: arquivos, sistemas operacionais, tráfego de rede e aplicações. A figura “Processo Forense (NIST SP800-86)” ilustra o processo de forense digital proposto pela SP800-86, o qual compreende quatro fases básicas: coleta (*collection*), exame (*examination*), análise (*analysis*) e relato (*reporting*).

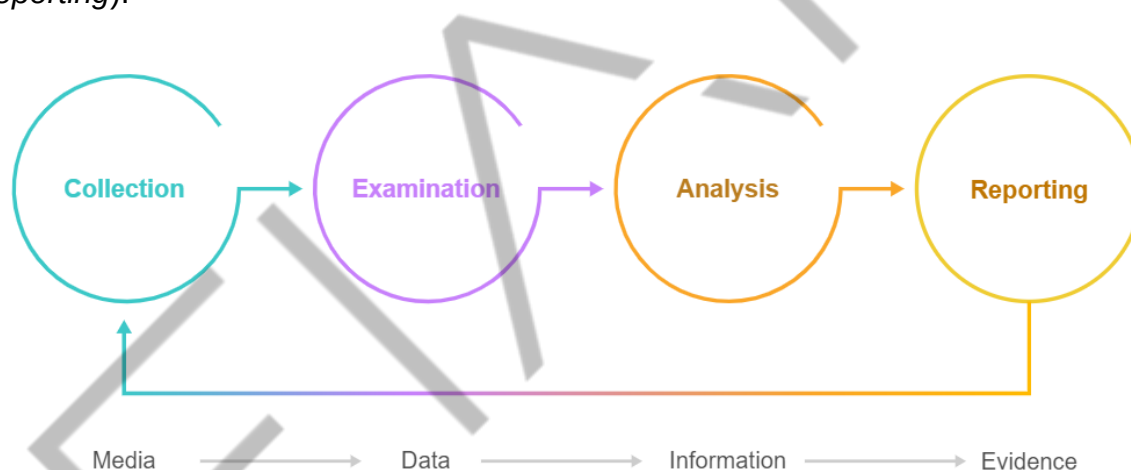


Figura 12 – Processo Forense (NIST SP800-86)
Fonte: NIST SP800-86 (2006)

A fase de coleta (*collection*), representada na Figura “Processo Forense (NIST SP800-86)” faz referência à identificação, etiquetagem, registro e aquisição de dados a partir das possíveis fontes relevantes.

A fase de exame (*examination*) remete ao processamento forense dos dados coletados, valendo-se, para tal, de uma combinação de métodos automatizados e manuais. Nesta fase procede-se à devida análise dos dados coletados, sendo então extraídos os dados com particular interesse para a investigação, enquanto é assegurada, também, a integridade de todos eles.

Na fase de análise (*analysis*), os resultados obtidos na fase de exame são avaliados por meio de técnicas e métodos legalmente justificáveis, a fim de se obter as informações que motivaram a investigação e a execução dos procedimentos anteriores.

A fase final do processo forense recai sobre o relato (*reporting*) dos resultados obtidos durante a fase de análise, o que poderá incluir a descrição das ações realizadas, explicando como os procedimentos e ferramentas utilizadas foram selecionados, e apontando quais ações complementares deverão ser eventualmente adotadas, como, por exemplo, a análise de fontes de dados adicionais e a melhoria de controles de segurança existentes. Esta fase oferece, ainda, recomendações para melhoria das políticas, diretrizes, procedimentos, ferramentas e outros aspectos relacionados ao processo forense.

A formalidade do relatório produzido ao final dos trabalhos pode variar bastante em função da situação. Vale dizer que a aquisição dos dados, durante a fase de coleta, deve observar três fases:

- Planejar a aquisição de dados priorizando as fontes de maior relevância, com base em fatores como: o provável valor desses dados para a investigação, a volatilidade dos dados e o grau de esforço necessário à aquisição.
- Aquisição (efetiva) de dados: a aquisição de dados envolve o uso de ferramentas forenses para coleta de dados voláteis e, ainda, a duplicação e preservação das fontes de dados não voláteis para coleta desses. A aquisição de dados pode ser realizada localmente ou através de rede. Embora seja geralmente preferível adquirir dados localmente, dado o maior controle sobre o sistema e dados, a coleta nem sempre é viável (por exemplo, caso o sistema esteja em sala fechada ou remotamente alocado). Na aquisição de dados via rede, deve ser considerado o tipo de dados a ser coletado e o esforço necessário para tal. Por exemplo, considere-se a possibilidade de aquisição de dados de diferentes sistemas utilizando-se para tal de múltiplas conexões de rede ou, alternativamente, procedendo-se à cópia de um volume lógico de um único sistema.

- Verificar a integridade dos dados: após a aquisição dos dados, a sua integridade deve ser verificada. Se destinados a propósitos legais, é especialmente relevante que o analista forense comprove que os dados adquiridos não foram adulterados. A verificação da integridade dos dados normalmente recai sobre a comparação entre o *hash* extraído a partir dos dados originais, e o *hash* extraído da cópia forense (duplicação) efetuada.

Dentre outras recomendações, a SP800-86 coloca ainda que as empresas procedam à análise forense valendo-se de processo consistente, como o anteriormente descrito e, ainda, que o analista (forense) deva ser capaz de reconhecer as possíveis fontes de dados. O analista forense deve valer-se de abordagem metodológica para análise dos dados adquiridos sendo que, se a evidência for necessária à ação disciplinar interna ou legal, o analista deverá documentar cuidadosamente suas descobertas e as medidas tomadas.

8.3 O EDRM – Electronic Discovery reference model

O EDRM representa uma visão conceitual do processo de *e-discovery* (*electronic discovery*) sendo composto por nove processos interligados, porém, independentes entre si (ARRUDA, 2018). O termo *e-discovery* apresenta diversas definições, podendo ser objetivamente entendido como o processo de descoberta, identificação, localização, recuperação e revisão de dados potencialmente relevantes em sistemas computacionais designados (EDRM, 2018).

Maura e Cormack (2011) complementam tal definição apontando o *e-discovery* como o processo de identificação, preservação, coleta, processamento, pesquisa, revisão e produção de Informações Armazenadas Eletronicamente (*electronically stored information* – ESI) que possam ser relevantes para uma questão civil, criminal ou regulamentar.

O modelo EDRM (Figura “O Modelo EDRM”) apresenta grande aderência ao ambiente corporativo, tendo como primeiro processo a *Information Governance* (Governança da Informação) o qual, descrito de forma bastante sucinta, tem como foco a organização do ambiente de produção (TI) da corporação a fim de mitigar riscos e reduzir despesas, abrangendo desde a criação até o descarte da ESI.

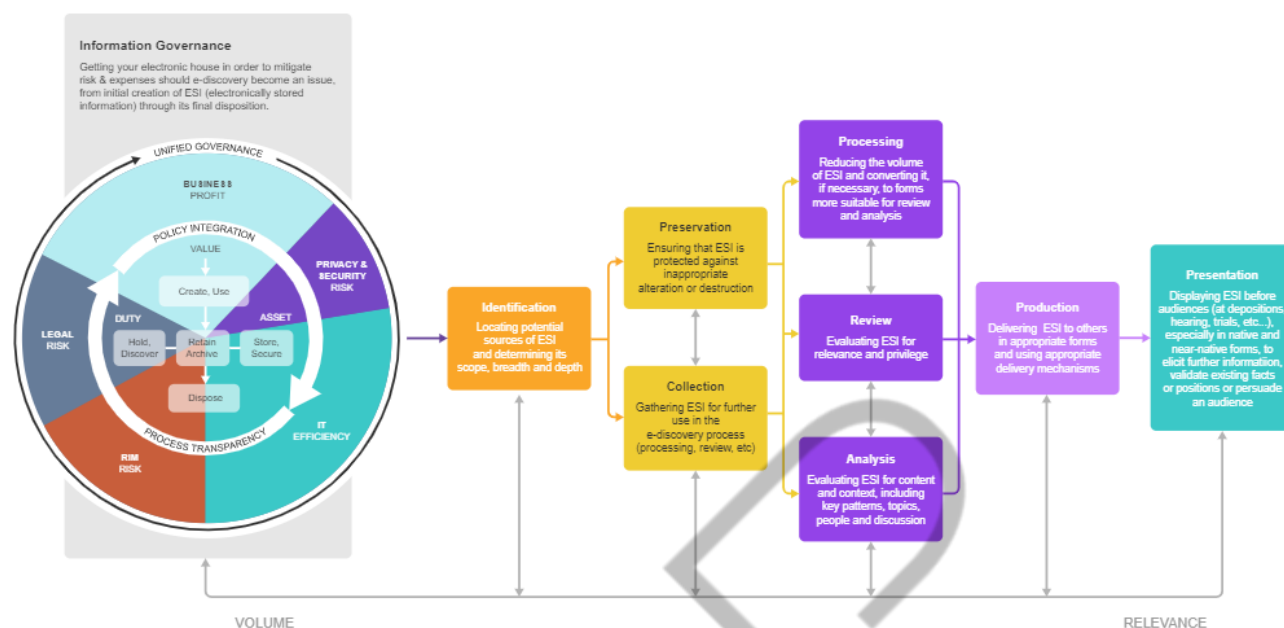


Figura 13 – O modelo EDRM
Fonte: EDRM Model (2019)

8.3.1 Identification

O segundo processo do modelo – *Identification* (Identificação), objetiva identificar as fontes de informação eletronicamente armazenada (ESI) potencialmente relevantes à demanda em curso, incluindo o escopo, abrangência e profundidade dessas. Tais fontes podem incluir unidades de negócios, pessoas, sistemas computacionais e mesmo arquivos em papel.

8.3.2 Preservation e Collection

O terceiro estágio do EDRM apresenta dois processos distintos: *Preservation* (Preservação) e *Collection* (Coleta). O processo de preservação tem como objetivo garantir que a ESI seja protegida contra alterações, ou destruição, indevidas. O processo de coleta tem como objetivo a aquisição de informações armazenadas eletronicamente (ESI) potencialmente relevantes, conforme definido na fase (processo) de identificação.

Demandas em litígios, investigações governamentais e investigações internas geralmente exigem que a ESI e seus metadados sejam coletados de forma juridicamente defensável, proporcional, eficiente, auditável e direcionada.

8.3.3 Processing

O processo de coleta de ESI poderá impactar e expandir o escopo do processo geral de *e-discovery*. O estágio seguinte é composto por três processos e iniciado pelo *Processing* (Processamento). Esse processo tem, resumidamente, como objetivo a redução do volume da ESI, convertendo-a, se necessário, em formas mais adequadas a revisão e análise. Os dados podem chegar ao estágio em vários formatos diferentes, precisando ser “restaurados” antes que o trabalho subsequente possa ser feito (*fitas, backups* etc.); arquivos individuais e *e-mails* podem precisar ser extraídos de arquivos *containers* (PST, NSF, zip, rar, dentre outros).

8.3.4 Review

Determinados tipos de dados poderão precisar de conversão para facilitar o processamento posterior (formatos de arquivos legados, por exemplo). Durante o estágio de processamento, itens individuais são catalogados e seus metadados associados são capturados.

Após o processamento da massa de dados coletada, inicia-se o processo de *Review* (Revisão) dos dados filtrados com objetivo de avaliação da ESI em relação à sua relevância e privilégios. Esta é a fase em que a equipe jurídica poderá obter melhor compreensão das questões factuais em um caso e na qual as estratégias jurídicas poderão emergir e começar a se desenvolver com base no tipo de informação que é encontrada na coleção de documentos processados.

8.3.5 Analysis

O último processo deste estágio é o de *Analysis* (Análise), o qual procede a avaliação da ESI com base em seu conteúdo e contexto, incluindo padrões-chave, assuntos e pessoas, dentre outros aspectos. As corporações buscam extensões baseadas em regras para seus sistemas de arquivamento, conformidade e investigação a serem aplicadas contra o fluxo de informações para (a) determinar se um item (arquivo, documento ou *e-mail*) é um registro de negócios e, portanto, deverá

ser retido; (b) categorizar os itens retidos segundo uma hierarquia corporativa, departamental, de projeto e de funcionários.

8.3.6 Production

O penúltimo processo do EDM, *Production* (Produção), cuida da entrega da ESI ao respectivo destinatário de forma, e por meio de mecanismos adequados; a fim de reduzir custos, riscos e erros, bem como estar em conformidade com as especificações e cronogramas de produção combinados. Com base na norma 34 do *Federal Rules of Civil Procedure* (FRCP), o EDM coloca ainda que, se uma solicitação não especificar o formato para produção da ESI, a parte deverá produzi-la da(s) forma(s) em que ela normalmente se apresenta ou em formato(s) razoavelmente utilizável(is).

8.3.7 Presentation

Por fim, o último processo do EDM recai sobre a Apresentação (*Presentation*), que se encarrega da exibição da ESI antes de uma audiência (em depoimentos ou julgamentos, dentre outros), principalmente em formatos nativos e quase nativos, para obtenção de maiores informações, validação de fatos ou posições existentes, ou ainda, para persuasão dos ouvintes. O EDM elenca algumas das metas e objetivos que deverão direcionar o processo de Apresentação, das quais se destacam aqui:

- Está se tentando persuadir ou informar?
- Quais fatos deseja-se demonstrar?
- Quais evidências adicionais existem?
- De quais tipos de ESI se dispõe?
- Quais partes da ESI alcançam as metas e objetivos pretendidos?

Ainda de acordo com este modelo de referência, uma evidência admissível em um tribunal de justiça é qualquer evidência testemunhal, documental ou tangível que possa ser apresentada a um “*fact finder*” – geralmente um juiz ou júri – a fim de estabelecer ou reforçar um ponto apresentado por uma parte no processo. Para que

a evidência seja admissível, ela deve ser relevante, sem ser prejudicial, e deve ter alguns indícios de confiabilidade.

9 HANDS ON – IDENTIFICANDO O OBJETO QUESTIONADO

Dos *frameworks* e modelos de referência abordados anteriormente observa-se ser fundamental a identificação correta do objeto questionado para garantirem os resultados do trabalho investigativo.

Tomem-se como exemplo mídias removíveis, como um HD externo ou um pen drive, ambos dispositivos muito difundidos entre os usuários e que, cada um em seu respectivo segmento, podem ser difíceis de distinguir entre si. Imaginem-se, agora, as potenciais consequências de um eventual vazamento de dados relacionado a um sistema de controle e gerenciamento de algum serviço crítico em uma *smart city* como, por exemplo, a configuração dos sistemas de sinais de trânsito ou sistemas de arrefecimento dos reatores de uma usina nuclear.

Suponha-se, ainda, que tais informações tenham sido gravadas por um *insider* em um HD externo ou pen drive, o qual deverá ser devidamente periciado.

Naturalmente, esse dispositivo removível precisará ser inequivocamente identificado conforme especificado, por exemplo, pelo processo de Identificação do EDRM antecedendo o início da investigação. Para este *hands-on* será utilizado o *VirtualBox*, com uma máquina virtual Linux (preferencialmente *Debian* ou algum de seus derivados), com o adicional de convidados instalado. A Tabela “Especificações da máquina virtual” traz as especificações para criação da referida máquina virtual.

Parâmetro	Especificação
Hypervisor	VirtualBox
Sistema operacional	Debian 9 64bits Stretch
Memória	1GB
Disco	8GB
Rede	Rede NAT
vCPU	1

Tabela 2 - Especificações da máquina virtual

Fonte: Elaborado pelo autor (2019)

Nesta primeira abordagem, assume-se ser o objeto questionado um HD externo. Para fazer com que esse seja reconhecido pelo *VirtualBox*, basta clicar em Dispositivo -> USB -> [id_do_dispositivo], conforme ilustrado na Figura “Reconhecimento do HD externo”.

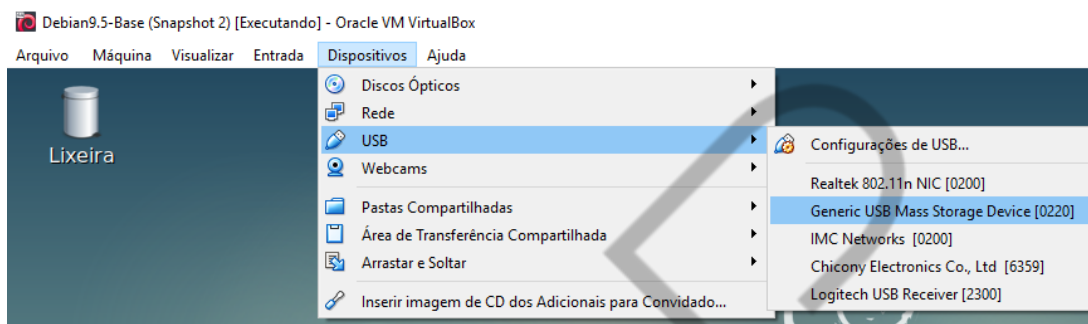


Figura 14 – Reconhecimento do HD externo

Fonte: Elaborado pelo autor (2019)

Depois de reconhecido com sucesso, o dispositivo estará pronto para ser identificado. Caso a distribuição usada já exiba automaticamente o conteúdo desse, a janela poderá ser fechada, pois os trabalhos serão desenvolvidos em linha de comando, portanto, deverá ser aberto um terminal em modo privilegiado (root). Nesse terminal, por meio do comando *df* será possível identificar o objeto questionado (destaque na Figura “Identificação do HD externo”).

```
user1@deb00:~$ su
Senha:
root@deb00:/home/user1# df -hT
```

Sist. Arq.	Tipo	Tam.	Usado	Disp.	Uso%	Montado em
udev	devtmpfs	992M	0	992M	0%	/dev
tmpfs	tmpfs	201M	5,6M	195M	3%	/run
/dev/sda1	ext4	8,3G	4,0G	3,9G	51%	/
tmpfs	tmpfs	1003M	0	1003M	0%	/dev/shm
tmpfs	tmpfs	5,0M	0	5,0M	0%	/run/lock
tmpfs	tmpfs	1003M	0	1003M	0%	/sys/fs/cgroup
tmpfs	tmpfs	1003M	4,8M	998M	1%	/opt/omd/sites/fiap/tmp
tmpfs	tmpfs	201M	8,0K	201M	1%	/run/user/1000
/dev/sr0	iso9660	56M	56M	0	100%	/media/cdrom0
/dev/sdb1	fuseblk	299G	286G	13G	96%	/media/user1/odra

```
root@deb00:/home/user1#
```

Figura 15 – Identificação do HD externo

Fonte: Elaborado pelo autor (2019)

Na figura “Identificação do HD externo” observa-se estar o objeto questionado montado em */media/user1/odra* – identificado como o dispositivo */dev/sdb1*, uma vez que o disco rígido da estação do investigador é identificado como o dispositivo */dev/sda1*. Agora, com o auxílio da ferramenta *hdparm* podem-se extrair informações detalhadas do dispositivo (Figura “Informações sobre o HD externo”).

```
root@deb00:/home/user1# hdparm -I /dev/sdb | head -n 7
/dev/sdb:
ATA device, with non-removable media
Model Number:      Hitachi HTS545032B9A300
Serial Number:     091121PBP306Q6DYXPUL
Firmware Revision: PB30C60F
root@deb00:/home/user1#
```

INFORMAÇÕES DO DISPOSITIVO

Figura 16 – Informações sobre o HD externo
Fonte: Elaborado pelo autor (2019)

Na figura “Informações sobre o HD externo” podem-se observar o modelo e número de série do dispositivo (objeto questionado), cabendo salientar, entretanto, que foram solicitadas somente as sete primeiras linhas da saída da ferramenta (head -n 7), sendo omitidas muitas outras informações relevantes do dispositivo, porém, não aderentes ao atual contexto. Para identificar-se agora um pen drive, o procedimento é um pouco diferente. Enquanto, no caso dos HDs externos, a *interface* de comunicação principal do dispositivo é padrão SATA, no caso de pen drives essa é USB e, assim sendo, ao invés da ferramenta *hdparm* será utilizada a ferramenta *lsusb* (Figura “Listagem de dispositivos USB”). Mais uma vez, inicia-se o processo fazendo com que a máquina virtual reconheça o novo objeto questionado. Para tal, novamente, basta acessar o menu da máquina virtual e, a partir da opção Dispositivos -> USB, clicar sobre o dispositivo USB desejado (Figura “Reconhecimento do pen drive”).

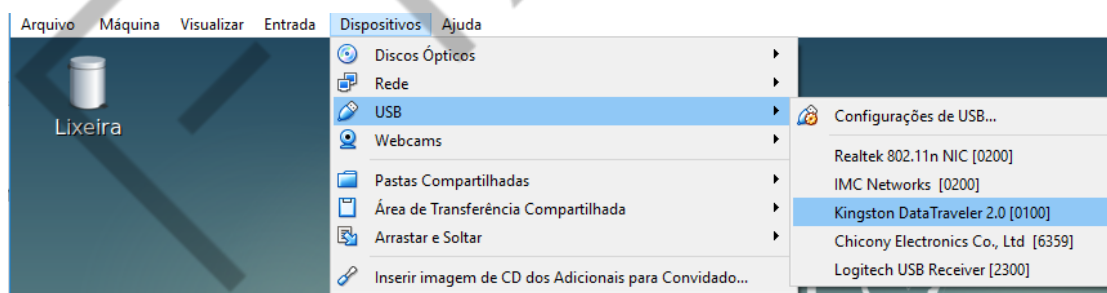


Figura 17 – Reconhecimento do *pen drive*
Fonte: Elaborado pelo autor (2019)

Analogamente ao HD externo, se o sistema operacional abrir uma janela exibindo o conteúdo do dispositivo, essa deverá ser fechada. A partir de um terminal, como *root*, executar a ferramenta *lsusb* (Figura “Ferramenta *lsusb*”).

```

user1@deb00:~$ su
Senha:
root@deb00:/home/user1# lsusb
Bus 001 Device 016: ID 0930:651e Toshiba Corp. TravelDrive 2C
Bus 001 Device 001: ID 1d6b:0002 Linux Foundation 2.0 root hub
Bus 002 Device 003: ID 80ee:0021 VirtualBox USB Tablet
Bus 002 Device 001: ID 1d6b:0001 Linux Foundation 1.1 root hub
root@deb00:/home/user1#

```

Figura 18 – Ferramenta *lsusb*
 Fonte: Elaborado pelo autor (2019)

No destaque (Figura “Ferramenta *lsusb*”) podem ser observadas as informações referentes ao objeto questionado, entretanto, essas ainda não são suficientes para correta identificação desse, fazendo-se necessário maior grau de detalhamento, por exemplo, a fim de apurar o número de série do dispositivo. Para tal, basta executar o mesmo comando, entretanto, de forma mais específica: solicitando à ferramenta *lsusb* que retorne maiores informações (opção *-v*, *verbose*), especificamente sobre os dispositivos (opção *-d*, *device*) designados pelo ID 0930:651e. Tais códigos referenciam, respectivamente, o fornecedor (*vendor*) e o produto (*product*) (Figura “Informações sobre o pen drive”).

```

root@deb00:/home/user1# lsusb
Bus 001 Device 016: ID 0930:651e Toshiba Corp. TravelDrive 2C
Bus 001 Device 001: ID 1d6b:0002 Linux Foundation 2.0 root hub
Bus 002 Device 003: ID 80ee:0021 VirtualBox USB Tablet
Bus 002 Device 001: ID 1d6b:0001 Linux Foundation 1.1 root hub
root@deb00:/home/user1# lsusb -v -d 0930:651e [1]

Bus 001 Device 016: ID 0930:651e Toshiba Corp. TravelDrive 2C
Device Descriptor:
  bLength                18
  bDescriptorType        1
  bcdUSB                  2.00
  bDeviceClass            0 (Defined at Interface level)
  bDeviceSubClass         0
  bDeviceProtocol         0
  bMaxPacketSize0        64
  idVendor                 0x0930 Toshiba Corp.
  idProduct                0x651e TravelDrive 2C
  bcdDevice                1.00
  iManufacturer           1 Kingston
  iProduct                 2 DataTraveler 2.0 [2]
  iSerial                  3 0851135172308957
  bNumConfigurations      1

```

Figura 19 – Informações sobre o pen drive
 Fonte: Elaborado pelo autor (2019)

A partir da saída da linha executada (Figura “Informações sobre o pen drive – [1]”), é possível identificar o fornecedor (*idVendor* – [2]), o produto (*idProduct* – [2]), o fabricante (*idManufacturer* – [2]), o modelo (*iProduct* – [2]) e o número serial (*iSerial* – [2]) do objeto questionado, informações necessárias ao início do preenchimento do formulário da cadeia de custódia (Figura “Formulário parcial da cadeia de custódia”).

Formulário de Cadeia de Custódia		
Caso nº: 001-18		Página: 01/01
Detalhes do equipamento / mídia eletrônica		
Item	Descrição	
01	Pendrive 512MB	
Fabricante	Modelo	Num. de série:
Kingston	Data Traveler 2.0	085113417230B957

Figura 20 – Formulário parcial da cadeia de custódia
Fonte: Elaborado pelo autor (2019)

A Figura “Formulário parcial da cadeia de custódia” ilustra os campos da cadeia de custódia relacionados à identificação do objeto questionado.

Embora estejam disponíveis diversos modelos diferentes do formulário de cadeia de custódia, não há um modelo padrão de uso obrigatório. Adicionalmente, sugere-se ainda, quando da elaboração do laudo pericial, o devido registro fotográfico do objeto questionado, dispensando-se especial atenção às particularidades que possam auxiliar em seu reconhecimento, tais como: arranhões, amassados, riscos, trincas e inscrições do fabricante, dentre outros. Tal prática alinha-se também com o prescrito pelo art. 170 do CPP (Código Processual Penal):

CPP – ART. 170 - DO EXAME DO CORPO DE DELITO, E DAS PERÍCIAS EM GERAL

Nas perícias de laboratório, os peritos guardarão material suficiente para a eventualidade de nova perícia. Sempre que conveniente, **os laudos serão ilustrados com provas fotográficas**, ou microfotográficas, desenhos ou esquemas.

A Figura “Registro fotográfico do objeto questionado” exemplifica o registro das particularidades do que poderia ser o objeto de uma perícia forense.



Figura 21 – Registro fotográfico do objeto questionado
Fonte: Google Imagens (2019)

E agora, que maturamos alguns conceitos e demarcamos até que ponto podemos atuar, entraremos em um tipo específico de perícia forense computacional, a perícia “*in vivo*”, tema do próximo capítulo.

REFERÊNCIAS

ARRUDA, O. D. R. **Preservação de evidências digitais em sistemas in vivo**: uma proposta para automatização do processo de preservação em sistemas Linux. 2018. Dissertação (Mestrado em Engenharia da Computação) – Instituto de Pesquisas Tecnológicas do Estado de São Paulo, São Paulo.

BARBOSA JUNIOR, S. J. B. **Crimes informáticos**: delitos virtuais no direito brasileiro. 2015. Disponível em <<http://www.egov.ufsc.br/portal/conteudo/crimes-inform%C3%A1ticos-delitos-virtuais-no-direito-brasileiro>>. Acesso em: 28 maio 2021.

BIRNFELD, M. A. **Escreva Direito**: prova e evidência têm definições diferentes. 2004. Disponível em: <https://www.conjur.com.br/2004-jun-11/prova_evidencia_definicoes_diferentes>. Acesso em: 28 maio 2021.

BRASIL. Constituição da República Federativa do Brasil de 1988. Emendas Constitucionais de Revisão. **Diário Oficial [da] República Federativa do Brasil**, Poder Executivo, Brasília, 5 out. 1988. Disponível em: <http://www.planalto.gov.br/ccivil_03/Constituicao/Constituicao.htm#art5xii> Acesso em: 14 jun. 2022.

BRASIL. Lei nº 11.690, de 9 de junho de 2008. Altera dispositivos do Decreto-Lei no 3.689, de 3 de outubro de 1941 – Código de Processo Penal, relativos à prova, e dá outras providências. **Diário Oficial [da] República Federativa do Brasil**, Poder Executivo, Brasília, 9 jun. 2008. Disponível em: <http://www.planalto.gov.br/ccivil_03/_ato2007-2010/2008/lei/l11690.htm>. Acesso em: 14 jun. 2022.

BREZINSKI, D.; KILLALEA, T. IETF. **RFC3227 Guidelines for Evidence Collection and Archiving**. 2002. Disponível em <<https://www.ietf.org/rfc/rfc3227.txt>>. Acesso em: 28 maio 2021.

CARVALHO, A. **Teoria do fruto da árvore envenenada**. 2015. Disponível em: <<https://mandi2005.jusbrasil.com.br/artigos/327697991/teoria-do-fruto-da-arvore-envenenada>>. Acesso em: 28 maio 2021.

CASTRO JÚNIOR, A.P.C. *et al.* **Forense Computacional em Memória Principal**. 2012. Disponível em < [Forense Computacional em Memória Principal | Semantic Scholar](#) >. Acesso em: 28 maio 2021.

CENTRO DE ESTUDOS, RESPOSTA E TRATAMENTO DE INCIDENTES DE SEGURANÇA NO BRASIL – CERT.BR. Incidentes Notificados ao CERT.br. 2023. Disponível em: <<https://stats.cert.br/incidentes/>>. Acesso em: 23 jun. 2022.

EDRM. **EDRM Model**. [s.d.]. Disponível em: < <http://www.edrm.net/frameworks-and-standards/edrm-model/>>. Acesso em: 28 maio 2021.

FARMER, D.; VENEMA, W. **Perícia Forense Computacional** – Teoria e Prática Aplicada. 4. Reimpressão. São Paulo: Pearson Prentice Hall, 2007.

GOMES, M. C. O. **Insiders e a segurança cibernética das empresas**. 2015. Disponível em: < [\(PDF\) Insiders e a segurança cibernética de empresas | Maria Cecilia Oliveira Gomes - Academia.edu](#) / >. Acesso em: 28 maio 2021.

HORSWELL, J. *The Practice Of Crime Scene Investigation*. New York: CRC Press. 2004.

KENT, K. *et al.* **Guide to Integrating Forensic Techniques into Incident Response**. 2006. Disponível em: < <https://csrc.nist.gov/publications/detail/sp/800-86/final>>. Acesso em: 28 maio 2021.

LAZARIDIS, I.; ARAMPATZIS, T. POURIOS, S. Evaluation of Digital Forensics Tools on Data Recovery and Analysis. **Proceedings of the Third International Conference on Weblogs and Social Media**, Thessaloniki, p. 67-71, 2009.

MAHER, M. **Becoming a forensic investigator**. 2021. Disponível em: < <https://www.sans.org/reading-room/whitepapers/forensics/forensic-investigator-1453>>. Acesso em: 28 maio 2021.

MARTINS, V. **Custódia de evidência digitais em processos judiciais e extrajudiciais**. 2018. Disponível em < <https://blog.sajadv.com.br/custodia-de-evidencias-digitais/>>. Acesso em 28 maio 2021.

MAURA, R. G.; GORDON, V. CORMACK Technology-Assisted Review in E-Discovery Can Be More Effective and More Efficient Than Exhaustive Manual Review. **Richmond Journal of Law and Technology**, v. 17, n. 3, p. 1-48, 2011. Disponível em <<http://jolt.richmond.edu/v17i3/article11.pdf>>. Acesso em: 28 maio 2021.

NIELLA, R. M. **Importância da cadeia de custódia**. Dissertação (Mestrado em Direito), Universidade Federal de Minas Gerais, Belo Horizonte - MG, 2001. Disponível em <https://repositorio.ufmg.br/bitstream/1843/BUOS-96MPWG/1/disserta__o_t_lho_lima_vianna.pdf>. Acesso em: 28 maio 2021.

NIST - National Institute Of Standards And Technology. **Forensic Examination of Digital Evidence: A Guide for Law Enforcement**. 2004. Disponível em: < <https://www.ncjrs.gov/pdffiles1/nij/199408.pdf>>. Acesso em: 28 maio 2021.

O ASSISTENTE técnico no código de processo civil. [s.d.]. Disponível em: < [O assistente técnico no Código de Processo Civil - Jus.com.br | Jus Navigandi](#) >. Acesso em: 28 maio 2021.

VIANNA, T. L. **Do acesso não autorizado a sistemas computacionais: fundamentos do direito penal informático**. Dissertação (Mestrado em Direito), Universidade Federal de Minas Gerais, Belo Horizonte - MG 2001. Disponível em: <<http://www.bibliotecadigital.ufmg.br/dspace/handle/1843/BUOS-96MPWG>>. Acesso em: 28 maio 2021.